

Web Cache Deception — Cache Path Mapping

Plataforma: PortSwigger Web Security Academy

Ferramenta: Burp Suite

Categoria: Web Security / Web Cache Deception

Escopo: Laboratório controlado

1. Objetivo

Demonstrar uma vulnerabilidade de **Web Cache Deception** explorando uma discrepância na forma como o servidor de origem e o mecanismo de cache interpretam o caminho de uma URL.

O objetivo específico do laboratório foi encontrar a chave de API do usuário **Carlos**, utilizando a conta disponibilizada pelo próprio ambiente de treinamento.

2. Descrição da vulnerabilidade

Web Cache Deception é uma vulnerabilidade na qual um atacante induz um servidor de cache, como uma CDN ou proxy, a armazenar dados privados e dinâmicos de um usuário.

Quando a vítima autenticada acessa uma URL construída de forma específica:

1. O servidor de origem pode processar a requisição como uma página privada ou dinâmica;
2. O cache pode interpretar o caminho como pertencente a um recurso estático;
3. A resposta dinâmica pode ser armazenada;
4. Posteriormente, a URL pode permitir acesso aos dados armazenados.

3. Conceitos observados

Path Confusion

Ocorre quando o servidor de origem e o proxy de cache interpretam a mesma URL de maneiras diferentes.

Extensões estáticas

O mecanismo de cache pode utilizar extensões como `.css` ou `.jpg` para identificar recursos considerados estáticos.

Requisição forjada

Uma URL pode combinar uma página sensível com uma extensão associada a recursos estáticos, fazendo com que uma resposta dinâmica seja tratada como conteúdo cacheável.

Armazenamento indevido

Uma resposta privada pode ser armazenada pelo cache quando o mecanismo interpreta a URL como um recurso estático.

4. Impacto potencial

A vulnerabilidade pode permitir:

- Vazamento de informações pessoais;
- Exposição de chaves de API;
- Exposição de tokens de sessão;
- Acesso não autorizado a dados de outros usuários;
- Comprometimento de contas quando credenciais ou tokens expostos forem reutilizáveis.

5. Ambiente e acessos

O laboratório forneceu:

- Uma conta comum sem privilégios administrativos;
- A página inicial da aplicação;
- A página **My Account**;
- Acesso ao ambiente controlado necessário para executar os testes.

6. Metodologia

6.1 Identificação do conteúdo dinâmico

A partir da conta disponibilizada, foi identificado o endpoint **My Account**, que retornava uma resposta dinâmica contendo uma chave de API.

6.2 Análise do mapeamento de caminhos

Foram investigadas diferenças na forma como o cache e o servidor de origem interpretavam os caminhos das URLs.

A análise considerou possíveis discrepâncias relacionadas a:

- mapeamento de URLs;
- caracteres delimitadores;
- normalização de caminhos.

6.3 Identificação de recursos estáticos

Foram analisadas extensões associadas a recursos estáticos, principalmente:

- `.css`
- `.js`

Também foi utilizado um caminho associado a `resources.js` para observar o comportamento do cache.

6.4 Construção da requisição

Após identificar a discrepância de comportamento, foi construída uma requisição utilizando o caminho capaz de explorar essa diferença.

A requisição foi enviada ao usuário-alvo do laboratório para provocar o armazenamento da resposta dinâmica no cache.

7. Análise do comportamento do cache

Durante os testes, foram observados cabeçalhos relacionados ao comportamento do cache:

- `Cache-Control`
- `Age`
- `X-Cache`

Em uma nova requisição, o cabeçalho `Cache-Control` apresentou:

`max-age=30`

Esse comportamento indicou que o recurso poderia ser armazenado temporariamente.

Também foi observada a alteração de:

`X-Cache: miss`

para:

`X-Cache: hit`

A mudança indicou que a resposta passou a ser servida pelo mecanismo de cache.

8. Construção e validação do ataque

Com o endpoint dinâmico, os recursos estáticos e a discrepância de mapeamento identificados, foi possível construir uma requisição que explorava o comportamento observado.

A exploração foi realizada exclusivamente dentro do ambiente controlado do laboratório e permitiu obter a chave de API solicitada.

9. Resultado

Status: Concluído com sucesso.

A exploração demonstrou que diferenças no mapeamento de caminhos entre o servidor de origem e o mecanismo de cache podem permitir o armazenamento indevido de conteúdo dinâmico.

A análise dos cabeçalhos `Cache-Control`, `Age` e `X-Cache` forneceu evidências do comportamento de cache observado durante a exploração.

10. Conclusão

O laboratório demonstrou, de forma prática, como uma discrepância de interpretação de caminhos pode transformar uma resposta dinâmica em conteúdo armazenado pelo cache.

A utilização do Burp Suite permitiu identificar o endpoint, analisar as respostas e validar o comportamento do mecanismo de cache.

O exercício reforça a necessidade de consistência entre o processamento de URLs realizado pelo servidor de origem e as regras utilizadas pelo mecanismo de cache.

11. Evidências

As evidências visuais da execução do laboratório serão mantidas separadamente deste relatório.

Elas poderão incluir:

- Requisições e respostas relevantes;
- Alterações dos cabeçalhos de cache;
- Validação do comportamento `X-Cache: miss` / `X-Cache: hit`;

- Evidência final da conclusão do laboratório.

12. Referência do laboratório

PortSwigger Web Security Academy — Web Cache Deception